

Security Management Plan - BAE Systems Plc

by Ross Greenall (CISO) 22503533

Table of Contents

[by Ross Greenall \(CISO\) 22503533](#)

[1 Introduction](#)

[1.1 Background](#)

[1.2 Purpose](#)

[1.3 Readership](#)

[2 Organisation of Information Security](#)

[2.1 Operational Model](#)

[2.1.1 Roles and Responsibilities](#)

[2.1.2 Organisational Chart](#)

[3 Asset Management](#)

[3.1 Asset Control](#)

[3.2 Asset Identification & Scope](#)

[3.2.1 Military Project Data \(Unclassified & Classified\)](#)

[3.2.2 Intellectual Property \(IP\)](#)

[4 Common Threat and Vulnerability Assessment Methodology](#)

[4.1 Threat Identification](#)

[4.2 Threat Identification Methodology](#)

[4.3 Common Threats](#)

[4.3.1 Nation-State Cyber Espionage](#)

[4.3.2 Supply Chain Attacks](#)

[4.3.3 Insider Threats](#)

[5 Risk](#)

[5.0.1 Common Vulnerability Scoring System \(CVSS\)](#)

[5.1 Risk Identification](#)

[5.1.1 Nation-State Denial of Service](#)

[5.1.2 Insider Threat Data Theft](#)

[5.1.3 Supply Chain Lateral Movement](#)

[5.1.1 Nation-State/Insider Threat Phishing Attacks](#)

[6 Controls](#)

[6.1 Control Frameworks](#)

[6.1.1 NIST Security and Privacy Controls 800-53](#)

[6.1.2 ISO/IEC 27001/2](#)

[6.2 Chosen Controls](#)

[6.2.1 NIST 800-53 SC-5 Denial-Of-Service Protection](#)

[6.2.2 Data Leakage Prevention ISO/IEC 27002 8.12](#)

[6.2.3 ISO 27001:2022 Annex A 5.21](#)

[6.2.3 NIST 800-53 AT-2 Literacy Training and Awareness](#)

[7 Auditing](#)

[7.1 ISO 27000 & NIST 800-53 Auditing](#)

[7.1.1 NIST 800-53 SC-5 Denial-Of-Service Protection Auditing Methodology](#)

[7.1.2 Data Leakage Prevention ISO/IEC 27002 8.12 Auditing Methodology](#)

[7.1.3 ISO 27001:2022 Annex A 5.21 Auditing Methodology](#)

[7.1.4 NIST 800-53 AT-2 Literacy Training and Awareness Auditing Methodology](#)

[7.2 Metric and Evidence of Success](#)

[References](#)

1 Introduction

1.1 Background

BAE Systems plc is a British multinational aerospace, defence and information security company. (Companies House, n.d.) BAE has a long standing history of air, land, sea and digital intelligence systems, stemming from its founding in 1999, through the acquisition of Marconi Electronic Systems by British Aerospace. Although the company is relatively young, being only 25 years old, it is the largest defence contractor in Europe and also one of the largest in the world (Defence IQ, n.d.).

With its primary headquarters located in London, England, BAE Systems employs approximately 100,000 people across 40 countries (BAE Systems, n.d.-a), providing, supporting, and developing products and services to protect national security from digital and physical threats. This multinational cross-platform business model has landed BAE Systems a half-yearly revenue of £13.4bn in 2024, a 13% increase from the same period in 2023 (BAE Systems, 2024). This high revenue stream allows BAE to operate on the cutting edge of technological advancement and as such facilitate their contracts which include military equipment, nuclear projects and highly secretive air, land and sea operations in cooperation with not only the UK Military of Defence (MOD) but other military departments across the world. But, with this increase in revenue, value, and contracts, comes a larger surface area for potential security breaches and incidents and as such a greater requirement for risk management and security controls.

In order to operate in the defence industry, there are a wide range of legal and regulatory requirements that BAE have to fulfil and maintain. In the United Kingdom, all defence equipment manufactured by BAE Systems is purchased by the UK MOD (BAE Systems, n.d.-b). To be eligible for MOD contracts, strict physical and digital security requirements are in place such as the Defence and Security Procurement Act 2023 and obtaining List X accreditation for secret MOD contract requirements (UK Ministry of Defence, 2017). On top of this, ISO 27000 certification is also heavily recommended and relied upon as it ensures secure practices in both the physical and digital areas of the business and its IT estate, this is established through asset assessments and strict controls to mitigate risk.

A primary source of concern for companies operating in the defence sector, falls under the rise of cyber-warfare and supply-chain vulnerabilities. One such incident occurred in May, 2024, with the UK Ministry of Defence falling victim to a deliberate information theft of former and current UK veterans (Coates, 2024). Breaches such as this impact defence companies operating closely with government military complexes, BAE Systems are a direct cyber supplier of the UK MoD and are as a result in direct risk of similar incidents due to both supply chain vulnerabilities but also the procurement of valuable military equipment data; including schematics, locations, designations and advancements.

1.2 Purpose

This document details the necessary structure, organisational, technical, and industrial requirements of BAE Systems, in order to secure information assets from both digital and physical risk vectors. This is detailed by showing the different departments and individuals whose roles help define and enforce controls that help mitigate and protect assets from these known and unknown risks, and as a result prevent security incidents from occurring which could result in severe reputational, financial, and legal damages to the business. As the Chief Information Security Officer, (CISO), it is my responsibility to define the necessary policies and protocols to best manage BAE Systems extensive information assets and business operations from physical and cyber threats.

1.3 Readership

This document is aimed at employees of BAE Systems, and internal and external auditors, who are required to understand the security management process that is present within the organisation. This report defines such roles and groups into an organisation chart to further establish the requirements of individuals and leaders within the larger security structure.

This document also contains several existing threats present within the defence industry, how they are assessed for risk, the controls in place to ensure these risks are mitigated and the overall auditing structure that continues to keep these information assets secure from physical and digital threats, now and in the future as the industry develops at a rapid pace.

2 Organisation of Information Security

2.1 Operational Model

The following section contains the details of the organisations internal cyber security structure, designed to align with a hybrid security framework. This section also includes the discussion of roles and responsibilities and a detailed organisational chart to further elaborate on the desired function of the cyber security division at BAE.

2.1.1 Roles and Responsibilities

Within BAE Systems, Information Security has been delegated and assigned into several teams consisting of key individual roles, this formulates a greater Information Security Management System (ISMS) that underpins all actions performed in the interest of BAE's cyber security, this includes the "establishing, implementing, operating, monitoring,

reviewing, maintaining and improving of the organisations information security to meet business objectives” (ISO, 2018).

Each team has a specific purpose, which in total collaboration provides an overall process made to meet the requirements of the organisations ISMS framework. This structure is tried and tested and recommended for implementation by organisations such as the National Cyber Security Centre (NCSC) in their board toolkit (NCSC, n.d), it also enables the alignment with key principles and controls listed in ISO 27000 and the NIST CSF 2.0 framework, both of which are utilised to reduce the risk of security threats to digital and physical information assets.

The major departments within the organisation are as follows:

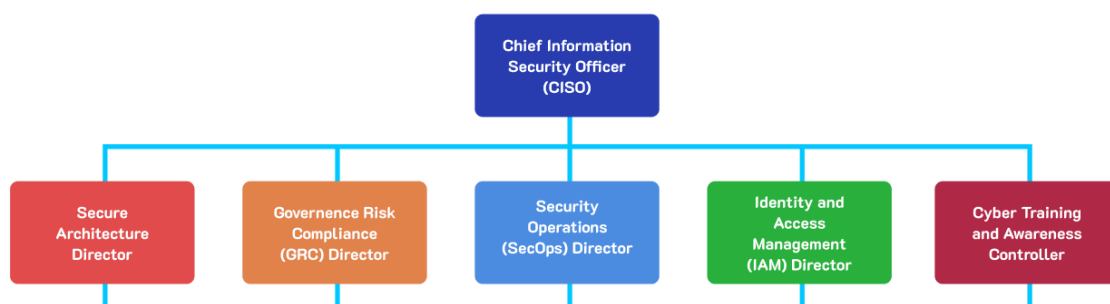
- **Secure Architecture**
- **Governance Risk Compliance (GRC)**
- **Security Operations (SecOps)**
- **Identity and Access Management (IAM)**
- **Special Projects and Innovation**
- **Cyber Training and Awareness**

Each departments primary function is mapped to a function within the NIST CSF framework; GOVERN, IDENTIFY , PROTECT , DETECT , RESPOND , and RECOVER (NIST, 2024). These functions act as the basis for all roles and responsibilities within the organisation and assist in mapping the cyber roles to the overall IT estate of BAE Systems.

2.1.2 Organisational Chart

BAE Systems has a large and extensive IT-estate that encompasses several different projects, devices, and technologies. The vast nature of this suite puts a large amount of pressure on key operating areas. Active and passive defensive systems must be maintained at all time, as with any other business, but an extra level of security is expected due to the nature of the contracts and operations performed by BAE, namely their defence contracts and ties with active military personnel within the MOD. The security of such projects and namely their individuals is considered to be highly sensitive information prone to threat from malicious entities.

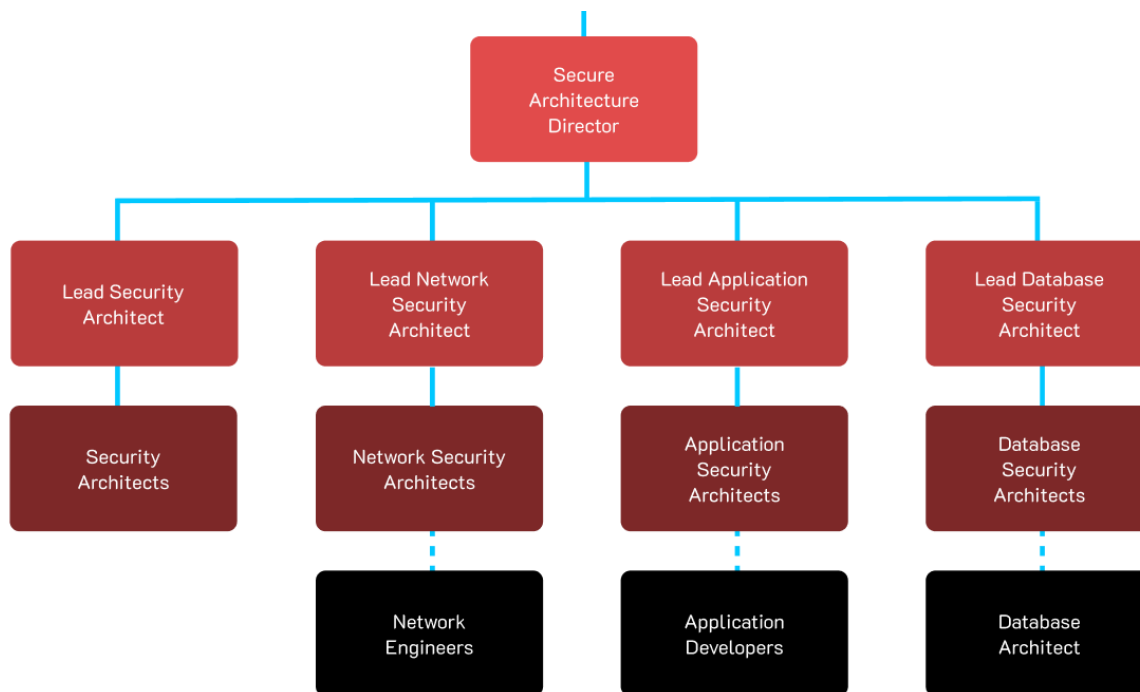
The organisations cyber security division, under the helm of the CISO, falls into 5 distinct departments that aim to further reinforce the NIST CSF framework primary functions (NIST, 2024). Each department then has further operation policies and frameworks to increase the efficiency and protection over the IT-estate and its assets.



Secure Architecture

The Secure Architecture department functions as the centre for all in-house security design, configuration, and implementation decisions. In coordination with the Governance Risk Compliance (GRC) department, the policies and controls that determine the decision making within the business are forwarded for implementation through different architecture teams; Network, Application, and Database. Any developments, implementations, and changes are forwarded to the GRC teams for appropriate assessment before they are enacted upon.

Each team also coordinates with its corresponding development department which operates outside of the purview of Information Security. These engineers report to both the Senior Engineers and Architects but also their corresponding Security variants.



Governance, Risk, Compliance (GRC)

Governance, Risk and Compliance (GRC), is tasked with designing and maintaining the structured approach to cyber security within the organisation. This is achieved through the implementation of policies, identifying and assessing risks and monitoring compliance across the IT-estate at BAE. (UK Cyber Security Council, n-d) This also applies to possible partners, ensuring compliance and structured cyber security functions to reduce the possibility of supply-chain attacks.

The GRC department is separated into three distinct teams. Governance, Risk, and Compliance. Governance handles the policies and frameworks that lay the foundation for cyber security within the business. The Risk team works in association with the larger business risk team to identify and assess cyber risks, this falls under the premise of IT being integral to business operations. Additionally, risk management make use of the NIST 800-30 framework to perform risk assessments which benefit in managing the overall cyber risk of the organisation. Compliance is then tasked with ensuring that the controls and policies set in place through the Governance and Risk departments are successfully introduced and maintained throughout the organisation, this in turn further lowers the possibility and impact of potential incidents when they inevitably occur.

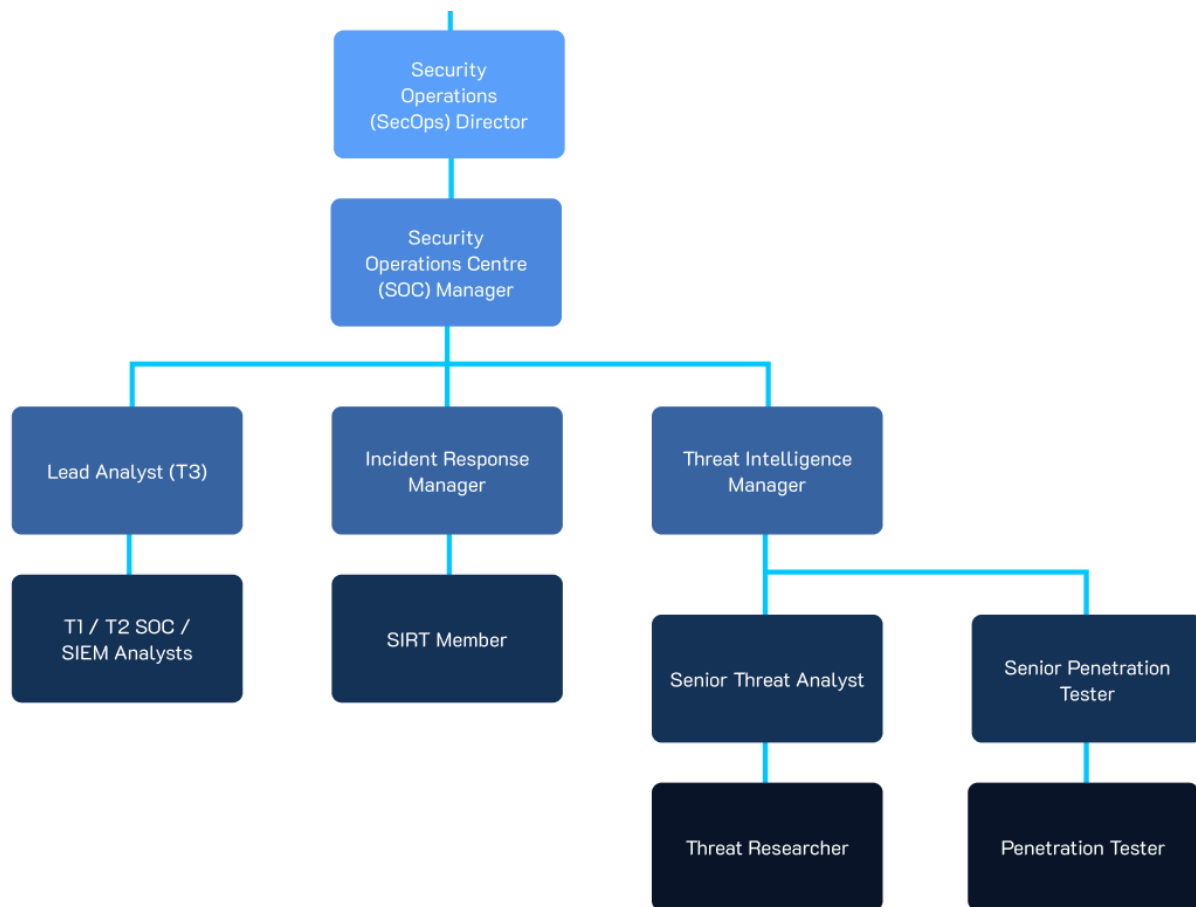
The GRC department is crucial in maintaining the quality and standards that are ultimately the lifeblood of the contracts that keep BAE in business, a failure in these roles could result in severe damages both reputational and financial so it is highly important that the roles and responsibilities are performed correctly. These departments help ensure that BAE meets the NIST CSF framework, providing GOVERN, which is the main backbone of all cyber operations within the business but also IDENTIFY, through risk assessments and management. Compliance is also closely tied to the RECOVERY (NIST, 2024) process also, with key changes being implemented and again reassessed for compliance.



Security Operations (SecOps)

Security Operations (SecOps) is the primary department focused on handling the active monitoring and incident response for the IT estate of BAE Systems. The epicentre of SecOps is the Security Operations Centre (SOC), which "is a central function in an organization where security experts monitor, detect, analyze, respond to, and report security incidents." (CrowdStrike, 2025). This falls under the DETECT and RESPOND functions of the NIST framework, where the SOC enables the timely discovery and analysis of anomalies (NIST, 2024). The combination of efforts through Governance and Risk assessments provides the desired detection and observation that is required to operate BAE's extensive networks and assets.

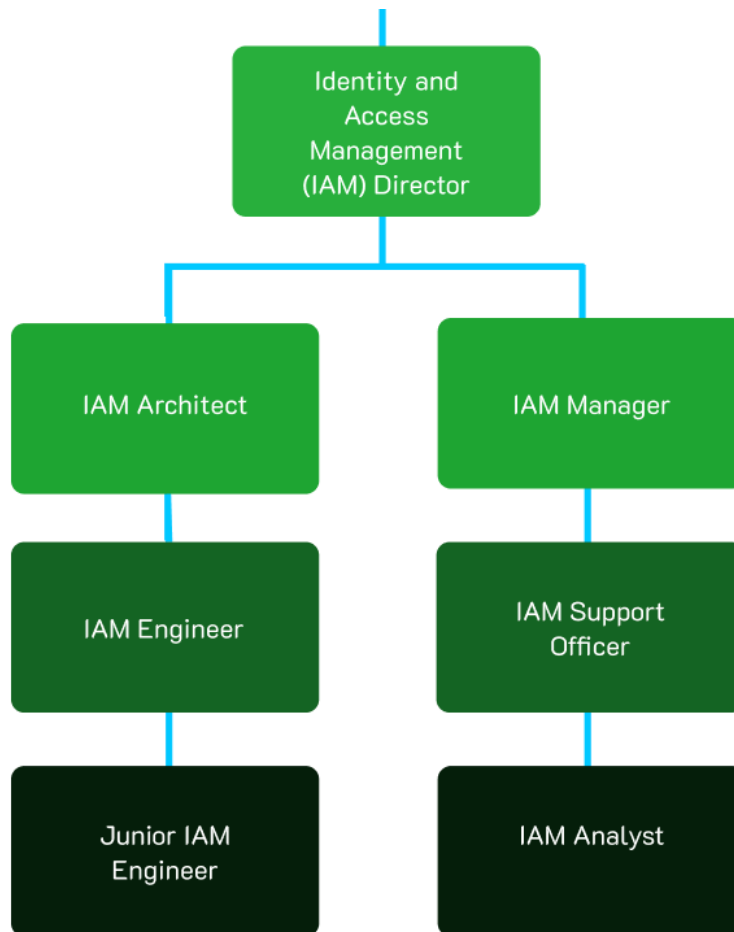
Security Operations also includes researchers to aid in the development and understanding of potential security vulnerabilities, these are then relayed to the other SOC teams as well as forwarded to the GRC department and Secure Architecture to prevent future implementations or uses of known vulnerable systems or programs. Auditing of the businesses security is primarily completed and tested by the internal threat intelligence teams which include both threat analysts and penetration testing teams, which in conjunction complete complex and thorough audits to ensure system security is of the highest quality possible. In extreme cases, external auditing teams with explicit permissions and extensive background checks to align with military contract requirements, may be requested to assist the internal teams with their work should the need arise.



Identity and Access Management (IAM)

Identification and Access controls are an important distinction when sensitive materials and contracts are present. With a complex and extensive IT-estate spanning across different territories and use cases, the authentication and authorisation management provided by this department is a focus point for security. IAM is related closely to the GRC and in turn the policies of access and controls are maintained tightly from a management perspective. This department primarily focuses on the Confidentiality and Integrity aspects of the overarching CIA triad (Fortinet, 2024). Although, it could be argued that the Parkerian Hexad is a better fitting model to understand the fundamental processes that makeup the organisations information security requirements, through the additions of Authenticity and Control/Possession. (Pender-Bey, 2012).

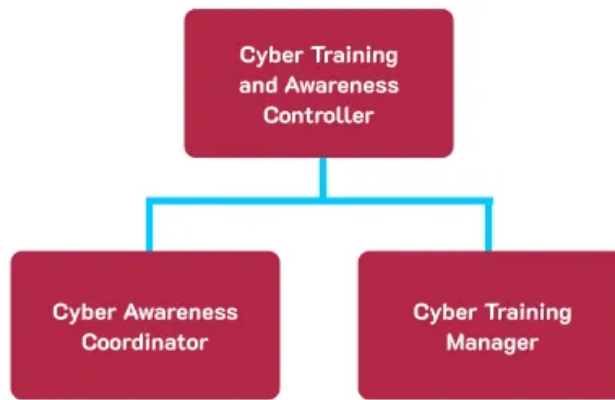
The roles within the IAM unit are closely matched with the NIST PROTECT Identity Management, Authentication, and Access Control subdivision (NIST, 2024) and the A.9 Access controls 14 controls found within the ISO 27000/1:2013. This helps distinguish and establish a clear process and understanding for the permitted access to materials, networks, files etc. User access management is also clearly defined with the registration and de-registration of users, management of privileged rights and review of such rights being adhered to under a specific governance policy, which is seconded and reassessed through the compliance team.



Cyber Training and Awareness

To further the importance of PROTECT within the NIST CSF Framework (NIST, 2024), the idea of awareness and training is a key concept to ensure all participating individuals across all business departments are capable of understanding the requirements set upon them by the cyber security teams. This focus on training individuals also coincides with the use of the ISO 27000/1 and 27000/2, which in turn creates a manageable environment for policy surrounding all levels of digital interaction within the business, and externally with third party suppliers and contractors.

The implementation of cyber training and awareness roles helps divide the responsibility of security across the business to all individuals, each person is held responsible for their own information and can then later be held accountable should their actions result in an increase of risk towards any digital assets. This methodology also gives those within the security departments more available resource to focus on identifying and protecting potential vulnerabilities and risks which can be relayed to the relevant departments without the need of external auditors where possible.



3 Asset Management

3.1 Asset Control

The scale of operations that are evident at BAE Systems makes the identification and management of digital assets a complex and important task. Information surrounding existing or future military defence contracts, propriety technical data and design blueprints, are just some examples of information assets that exist within the IT storage network of the organisation. These assets must not only be protected from external interference but also internal tampering from rogue individuals.

Below are two examples of information assets that are integral to the day to day operations of BAE Systems. These assets ensure continued meeting of contract specifications and the development of future defence technology usable by various military departments around the world.

3.2 Asset Identification & Scope

3.2.1 Military Project Data (Unclassified & Classified)

BAE supplies numerous countries with military equipment both physical and digital. The data that surrounds these contracts, such as the products requested, quantities, services and other key details are stored within the BAE network. This information helps continue the steady growth of sales revenue that is visible in the half-yearly report. (BAE Systems, 2024). A clear example of this data in a business context is the recent \$2.5 billion deal between Denmark and Sweden for CV90 Combat Vehicles, the details of which are kept on file at BAE. (BAE Systems, 2024-b). The preservation these information assets and the confidentiality that surrounds them is also important in the case of security products. With privacy and non-publication being closely related to the efficiency and use cases including reconnaissance and offensive security activities. This again links back to the extensive requirements of military contracts and the standards which must be maintained to protect sensitive information.

3.2.2 Intellectual Property (IP)

Another information asset which is crucial to BAEs operations is the wide variety of patents owned and controlled by the company. BAE is responsible for some 2,500 inventions worldwide through patents and patent applications (BAE Systems, 2024-c). These patents range from machine learning algorithms to hydrogen based weapon systems, all of which are intellectual property of BAE systems and many of which are in active deployment across the world by various militaries including the UK and USA (BAE Systems, 2024-d). The technical details and blueprints that exist during the research and development phases of these technologies must be kept securely and away from potential threats that would use the information to create counterfeit copies of proprietary technologies. The outcome of such a scenario would create a loss in both reputational and financial value of the company and its existing relationships in the wider defence community.

4 Common Threat and Vulnerability Assessment Methodology

4.1 Threat Identification

With several key assets identified above, the importance of security is made ever more clear. Due to the vast and complex network that BAE operates, the identification of threats by the security operations internal threat intelligence teams is evident and the attack surface for possible threats becomes wider with every new contract and technological addition or deployment. To help counter this ever growing security risk, the identification of common or known threats is established within the business and then applied to new contracts as they are created.

4.2 Threat Identification Methodology

With an internal team responsible for the identification and categorisation of threats, namely within the SOC, which collaborates with the GRC teams who perform risk analysis based on the information discovered through the threat identification teams, the requirement of a reliable and repeatable methodology for threat identification is evident.

The process of this methodology begins with understanding the scope of the assets that are being protected, namely in these examples the Military Project Data and Intellectual Property. With the business operating in numerous countries at varying levels of security clearance provided by the state, the risk of incident is extremely high at all times, and all possibilities and avenues of incident must be identified and assessed in due time to keep up with the pace of the business.

Secondly, the assets are evaluated in a process that discovers the possible vulnerabilities that exist within the assets and the systems that they exist in, that could develop into a threat should no action be taken by the organisation to protect said assets.

Following the identification of these vulnerabilities, a systematic approach of vulnerability assessment occurs, in which several tools such as a Common Vulnerability Scoring System (CVSS) is used to ascertain the severity of the vulnerability, which could later be exposed to a possible threat actor. This information is then relayed to the GRC where the implications of the vulnerability are discussed, and a level of prioritisation is established in accordance with the cyber security frameworks.

After prioritising these risks, controls are put in place to help mitigate the risks and protect the information assets. Several controls may reside over multiple assets providing a stronger level of security and reduction in risk, providing the controls are adhered to and regularly audited. The auditing of these controls is the final step of the methodology which provides continued insurance that the control is functioning as intended, which is made clear through the use of metrics and key performance indicators.

4.3 Common Threats

The defence industry is subject to heavy bombardments of cyber attacks that mostly come from state funded cyberwarfare divisions that exist within other countries military estates. With major examples including StuxNet, SolarWinds and WannaCry being some infamous examples (Check Point Software Technologies, n.d.). However, not all attacks that are present within the defence industry occur from external military outfits, often vulnerabilities in partner systems and insider threats can provide a different level of difficulty. Here are several examples of threats that could result in potential damage, loss or exfiltration of the aforementioned information assets.

4.3.1 Nation-State Cyber Espionage

State sponsored threat actors targeting defence contractors to steal classified information is an ever growing issue, with cyberwarfare quickly becoming an integral part of modern day warfare. Control over enemy networks, devices or classified data provides a unique advantage that can turn the course of conflicts and result in an increase in casualties. BAE Systems has an obligation to both its shareholders and partners to protect the sensitive information stored within its systems, especially in the case of military project data, the exfiltration of such data through a state-sponsored data breach would be devastating for both parties and also innocent civilians should the data in question lead to an increase in casualties. Nation states may also specifically target the research and development division of BAE Systems in an attempt to steal intellectual property before it is patented, resulting in the strengthening of opposing military forces as a direct result of exfiltrated information assets.

It is clear then that Nation-State Cyber Espionage, is an ever present threat to all information assets and systems that BAE operates, regardless of the assets individual value as any information could be used to great affect against the military organisations that rely on BAE for there contracts and security solutions.

4.3.2 Supply Chain Attacks

Cyber adversaries will not only attempt to exploit vulnerabilities on BAE networks explicitly, they may also target third party providers and suppliers of BAE such as parts manufacturers, materials suppliers and digital service providers in an attempt to perform a supply chain attack. Threat actors will use vulnerabilities in these systems to gain unauthorised access to closely related information assets and use those to attempt to gain access into the BAE network and make use of the information assets we have previously mentioned. It is necessary then that BAE limits to the best of its ability the number of third parties that it relies on to the smallest number possible without inhibiting the performance of the business, this limiting and prioritisation must be analysed and taken into consideration when determining the risk associated with partnership arrangements.

A key example of a government run institution, the National Health Service (NHS) falling victim to a supply chain attack came in June of 2024, when a pathology lab was subject to a ransomware attack which led to disruption across the NHS and data being stolen. (BAE Systems, 2024-e). With BAE operating in close relation to the MOD

4.3.3 Insider Threats

Though external threats provide the majority of the makeup of potential security incidents, insider threats must also be considered a possibility due to a number of reasons. Rogue employees, either those who are disgruntled or who have been offered some form of financial gain in exchange for sensitive information, can prove to be an extremely damaging threat actor. Because they operate from behind the firewalls and standard network traffic analysis performed by the Security Operations team, it is hard to detect when information assets are being exfiltrated, altered or damaged by seemingly trustworthy individuals. One of the most famous examples of a rogue insider threat comes from the case of Edward Snowden, regardless of opinion on his actions, through Snowden's authorised access to the National Security Agency's information assets, he was able to exfiltrate sensitive data without the knowledge of system administrators (Securonix, n.d.). This same threat is a possibility for the information assets we have proposed, with mission critical data being at risk from seemingly trust worthy individuals.

5 Risk

As we have identified some examples of threats that could inflict damage to our information assets, its important to then establish the risks that are associated with these threats and prioritise the mitigation of these risks in a way that both limits their impacts but also allows the business to continue to reach its operational objectives.

5.0.1 Common Vulnerability Scoring System (CVSS)

The CVSS takes into consideration several factors to establish a consistent scoring system to assist in the identification and prioritisation of risks. This in turn helps the GRC team best mitigate the risks whilst maintaining the objectives of the business without disturbance. The following factors are key in assessing risk using the CVSS; attack vector, attack complexity, privileges required, user interaction, scope, CIA triad. (Risto, 2023). All scores for the assessed risks were calculated using the National Vulnerability Database CCVS Scoring System calculator (NIST, 2025).

5.1 Risk Identification

5.1.1 Nation-State Denial of Service

The threat of state-funded threat actors is evident due to the increase in these attacks at an alarming rate. One such action of these so called groups is the use of denial of service attacks. A Distributed Denial of Service attack or DDoS is an attempt to disrupt normal traffic of a target network or service by overwhelming the target infrastructure with a flood of traffic. (Cloudflare, n.d.). Due to the increased funding that comes with national backing, the increase in quantity in traffic or members of the botnet results in catastrophic damage when targeted at a small number of specifically identified networks or services.

The potential damage to business operations is massive if protection measures such as adequate firewall systems and isolated networks are not utilised properly. Within the CIA triad, the availability of key business functionality and information asset management would be severely hindered and depending on the longevity of the DDoS, some assets would be non-accessible for several days, which in the case of Military Project Data could result in potential loss of life depending on specific scenarios that could occur in the field.

In assessing this risk using CVSS, the following ratings would be applied in the case of DDoS:

CVSS Factor	Level
Attack Vector	Network
Attack Complexity	High

CVSS Factor	Level
Privileges Required	None
User Interaction	None
Scope	Changed
Confidentiality	None
Integrity	Low
Availability	High

Overall CVSS Score: 7.5

5.1.2 Insider Threat Data Theft

The threat of an internal employee going rogue and taking advantage of permissions and access rights for financial gain is a major concern especially within the defense industry. With classified documents and technological advancements being worth a lot of money to the right buyer. With examples such as MBDA Missile Systems data being available for purchase in bitcoin estimated at approximately £273,000 for 80GB of information (BBC News, 2022). It is clear then that even smaller amounts of data which could be exfiltrated without knowledge from BAE Systems network. This exfiltration could affect both information assets identified above, with a primary focus on military project data much like the missile systems manufacturer MBDA.

Although, insiders would be unlikely to attempt to modify, tamper or remove data entirely as this would leave a more permanent action that would be traceable back to their user accounts through system logging and network analysis completed by the SecOps department. The impact of the data theft would most likely fall into the category of reputational and financial damages which would produce less of a disruption to business objectives than other identified risks, possibly highlighting it as a lesser priority risk factor. In regards to the CIA triad, primarily Confidentiality would be heavily affected with external parties having unauthorised access to data from inside of BAE Systems but also in rare cases where data is tampered with, the integrity of this data could also be put into question.

In assessing this risk using CVSS, the following ratings would be applied in the case of Data Theft:

CVSS Factor	Level
Attack Vector	Local
Attack Complexity	Low
Privileges Required	Low/High
User Interaction	Required
Scope	Unchanged
Confidentiality	High
Integrity	Low
Availability	None

Overall CVSS Score: 5.6

5.1.3 Supply Chain Lateral Movement

With a range of suppliers, including physical and digital services and goods, that BAE relies upon to operate its business as well as close connections through shared networks and data sources with clients including state military outfits, the risk of supply chain attack is higher than in other business cyber environments. Supply chain attacks occur when products, services, or technology you are supplied with have been breached or compromised and are in turn used to infiltrate and further compromise your own systems (Information Commissioners Office, 2023). To fully assess the risk of supply chain attacks, not only do internal assessments on the companies systems have to be completed but also checks to consider whether associated third parties are maintaining the same standards within their own organisations and systems. There are many examples as previously stated under the common threats section in recent times which have resulted in major financial losses and reputation damage impacting different businesses ability to meet their target objectives. Some of these include SolarWinds, log4j, Kaseya, and Spring4Shell (Information Commissioners Office, 2023).

Because of this reliance on other security personnel from outside companies to perform and protect their own dedicated infrastructure, it becomes a difficult task to identify and understand the severity of potential attacks. It is better to assume then that these attacks are severe and require a higher level of prioritisation, especially securing channels in which inter-business communication through shared networks or resources is present. This is expected

even more so in the cases where the communication occurs between BAE Systems and organisations such as the MOD.

In assessing this risk using CVSS, the following ratings would be applied in the case of Supply Chain Attacks:

CVSS Factor	Level
Attack Vector	Adjacent Network
Attack Complexity	High
Privileges Required	High
User Interaction	Required
Scope	Changed
Confidentiality	High
Integrity	High
Availability	High

Overall CVSS Score: 7.3

5.1.1 Nation-State/Insider Threat Phishing Attacks

Phishing attacks are one of the most common attacks present in modern day cyber security. With 56% of all businesses within the United Kingdom reporting phishing breaches or attacks in the past 12 months (Information Commissioners Office, 2024). Phishing attacks occur when threat actors use forged messages to fool individuals into sending sensitive information, pay money or click on links that contain viruses or redirect the user to a fraudulent website (Information Commissioners Office 2024). Two of the previously identified threat actors both Nation-State and Insiders could perform this type of attack, meaning that there is a wider surface area that is at risk, increasing the prioritisation in regards to mitigation.

Nation-State attackers could send spam emails to individuals within BAE systems in an attempt to gain a foothold within the network, this could later be used in the case of an Advanced Persistent Threat (APT) where a long term attack occurs that is highly methodical and aims to go under the radar for several months or even years until a specific goal of data exfiltration or system damage has been reached. Alternatively, insider threats could make use of personal private information such as senior figures email addresses to launch a more focused phishing campaign known as spear phishing, this attack would make use of information known only to employees of BAE to increase the reputation of the message, which in turn increases the probability of success.

This wide attack surface makes mitigating these attack types harder, increasing the prioritisation to defend the company from this risk. And as a result, two separate CVSS calculations are required to determine the underlying score depending on the position from which the attack was made.

Nation-State Phishing

CVSS Factor	Level
Attack Vector	Network
Attack Complexity	Low
Privileges Required	None
User Interaction	Required
Scope	Unchanged
Confidentiality	Low
Integrity	Low
Availability	Low

Overall CVSS Score: 6.3

Insider Phishing

CVSS Factor	Level
Attack Vector	Local
Attack Complexity	Low
Privileges Required	None
User Interaction	Required

CVSS Factor	Level
Scope	Unchanged
Confidentiality	Low
Integrity	Low
Availability	Low

Overall CVSS Score: 5.3

6 Controls

Security controls are mechanisms designed to protect systems from threats, the term security controls refers to any safeguard or countermeasure used to avoid, detect, counteract or minimize security risks to information assets (IBM, 2021). Following the threats and risks that we have identified in relation to BAE Systems, and the organisational structure that was designed with the NIST CSF framework in mind, it is important then that security controls are applied and enforced across the organisation, this implementation of controls will help to mitigate the risks identified and as a result enable the organisation to reach its intended organisational objectives with minimal disturbance from threat actors.

6.1 Control Frameworks

6.1.1 NIST Security and Privacy Controls 800-53

With the organisation adopting the NIST CSF 2.0 Framework as its primary cybersecurity framework, primarily to help direct the broader cybersecurity design and process across the organisation and its departments, it is only reasonable that the NIST Security and Privacy Controls 800-53 v5.1 is adopted partially to help introduce controls that will mitigate specific risks and maintain the higher structure developed in the organisational chart and specific role responsibilities (NIST, 2020).

Within the NIST 800-53, there exists a number of controls that could be applied to our identified risks, each of which can be introduced, followed and finally audited on a semi-regular basis to ensure these controls are being successfully and properly implemented and engaged with at all levels. It may also be a requirement of third parties that engage with BAE Systems to also follow and audit their own structure following the same or similar control methods.

6.1.2 ISO/IEC 27001/2

Additionally, ISO/IEC 27001/2 are international standards that provide another list of controls that can help an organisation maintain a strong standard in security. Much like NIST 800-53, ISO 27001/2 helps BAE maintain and protect its so called CIA triad as well as continuously improve its ISMS.

Not only is this important, but many contractual requirements relating to information security can be reached and maintained with the implementation of ISO 27001/2. Additionally, the requirement of ISO certification may be required for contracts dealing with the Ministry of Defense within the UK but also external government contracts will require similar security standards (Securious, 2025).

6.2 Chosen Controls

6.2.1 NIST 800-53 SC-5 Denial-Of-Service Protection

Within the System and Communications Protection control family of the NIST 800-53 framework, we can see that control SC-5 refers to Denial-Of-Service Protection. This control highlights multiple sub-controls that can help BAE mitigate the risk of these Nation-State funded DDoS attacks that could cripple vital infrastructure.

Firstly, "Organizations can limit the ability of individuals to use excessive system resources." (NIST, 2020), this control can be achieved by implementing a rate-limiting system and firewall protection from a vendor such as CloudFlare, through this rate-limiting and filtering system a limited number of requests can be made by each individual host, this drastically reduces the amount of traffic from each host machine within the threat actors botnet, which mitigates a large amount of damage and downtime that an attacker could use to target BAE. The downside to this rate-limiting is that additional network filtering must be implemented at a huge cost, with the size of BAEs infrastructure the amount of money required to gain a contract with a company such as CloudFlare would be massive. Not only this but introducing another third party vendor adds another point of risk in terms of a supply chain attack.

However, due to BAE having a dedicated cyber security software development department, an internal task force could be assembled to design and implement another control such as detection and monitoring using specialised software developed internally. This reduces the outward cost and also helps to reduce the possibility of a supply chain attack through a third party vendor.

6.2.2 Data Leakage Prevention ISO/IEC 27002 8.12

Within ISO/IEC 27002 there exists controls to help manage user rights and management of information assets, within these lists of controls there exists control 8.12, the Data Leakage Prevention control. This control purpose is to detect and prevent unauthorised disclosure and extraction of information by rogue individuals or systems (Kosling, 2024). The impact and risk of internal threat actors has been highlighted in the previous sections and as a result it is imperative that these risks are mitigated using the necessary controls and guidance.

To assist in the implementation of this control, several key actions can be taken. Initially the identification and classification of important information assets is the first place to start. This implies that users who should not have permissions to view sensitive documents, are restricted from viewing, editing, deleting or retrieving them without proper authorisation, this helps again to maintain the confidentiality of the information assets. Secondly, internal monitoring of data transfer channels including emails, file transfers, mobile devices and portable devices must be strictly controlled within the organisation. The digital information must be monitored by the SecOps team to help ensure that critical data such as military project plans and intellectual property is not communicated to unauthorised persons within the business, additionally physical security such as external mobile devices and portable storage mediums such as USB sticks must be stored appropriately and unable to be used within range of information assets.

These two actions greatly reduce the risk of insider data theft but come at the cost of additional security resources facing internally rather than on external threats, and the requirement of further physical employees who must be vetted and audited to ensure that they are successfully implementing the controls that have been put into place. Although it is not a perfect solution, the training introduced through the Cyber Awareness department would also help to encourage individuals at all levels of business operations on the importance of maintaining these security controls which would further mitigate the risk of insider threat actors.

6.2.3 ISO 27001:2022 Annex A 5.21

As previously discussed, third party suppliers of services and goods must maintain a level of security that is mutually agreed upon by both parties. In the case of BAE, these third parties may be military organisations or other government/private entities. In order to operate and help to mitigate the risk of supply chain attacks from insecure partners, the introduction of controls is a necessary requirement, one that must be implemented by both parties at an agreed level of security. A key control that can be used to maintain this standard is the ISO 27001 Annex A 5.21, namely Managing Information Security in the ICT Supply Chain (Kosling, 2024).

This control is more of a preventative control, existing as a standard to be maintained rather than a specific digital action to mitigate the risk on information assets, additionally, it more affects the communication of military project data than the intellectual property that would not be communicated between third parties. Some of the actions that are suggested in the 5.21 control are that the supplier must communicate the organisation's security requirements to any vendors or suppliers they use when the need arises to acquire components (physical or virtual) from third parties (ISMS, 2022). This implies that discussions surrounding security requirements for both physical and digital assets be completed between parties prior to beginning any form of interaction between each other. The upside to this is that BAE can directly understand the levels of security that a third party operate under and understand the appropriate risks that coincide with these security levels before transfer of information assets occurs, however, due to this communication occurring there is a noticeable delay in the process of transferring new materials and information assets, in the case of military project data this could have a large impact on the success and swiftness of the delivery of technical details, which could impact the success or deployment of mission critical equipment. But it can be noted that once the level of security is understood and a long lasting understanding has been implemented, there will be an increase in the smoothness and security of operations going forward, especially when state military projects are concerned.

6.2.3 NIST 800-53 AT-2 Literacy Training and Awareness

Finally, a control that directly relates to the Cyber Awareness and Training department tasked with implementing security understanding across the business, has a direct control to assist in the mitigation of attacks that are directly associated with the quality of this department's training and its results. The risk of phishing has been noted as one of the most common forms of social engineering attack that faces the majority of business operating in the world, even more so those that have a direct link to state operated industries such as hospitals, military or otherwise (Information

Commissioners Office, 2024). In response to this, BAE can introduce controls that further mitigate the risk associated with phishing attacks from both external and internal threat actors.

The AT-2 Literacy Training and Awareness controls creates a standard of understanding for new employees and also through the assistance of auditing and regular checks maintains a standard of cyber security knowledge amongst all employees with any access to networks, file systems or information assets. This could also be applied through the third party security standards to extend the reach of the security training program when dealing with BAE.

Examples of actions that can be taken to increase the standard of awareness and security literacy are as follows. Providing practise exercises in literacy training that simulate events and incidents (NIST, 2020), this action could help to replicate the necessary actions and understanding surrounding security incidents and reduce the level of panic that occurs when a real incident has happened. The only downside to this would be a minimal amount of time and money spent into training and completing the incident but this would be beneficial and prove a greater value over time. Additionally, BAE could Provide literacy training on recognizing and reporting potential and actual instances of social engineering and social mining (NIST, 2020). This action would help to greater the recognition of phishing and spear phishing attacks that could occur from both external and internal threat actors, if identified early a mass phishing attack could be thwarted with almost immediate effect by the SecOps teams, with a minimal investment and training program the chance of this attack becoming a reality is greatly reduced with little to no external assistance required.

7 Auditing

Following the implementation of controls and their recommended actions to mitigate the risks associated with our chosen information assets, the maintenance and continually improvement of these methods is imperative to the continued success and operation of the day to day business at BAE. In order to ensure that each specific department or individual is performing and continuing to operate by the controls that have been applied, internal and external auditors are required to check and reassure management that the level of security is where it should be. This auditing can come in many different forms and can be completed by an internal or external auditor or auditing team.

7.1 ISO 27000 & NIST 800-53 Auditing

Alongside our existing controls, which follow a hybrid framework combining the NIST 800-53 control framework with the ISO/IEC 27000 suite of controls, an appropriate place to start the auditing process from would be to coincide with the achievement of the ISO 27000 accreditation. To achieve this, an auditor must ensure that the company in question, in our case BAE, meets the requirements of the ISO accreditation (AuditBoard, 2023).

It is clear then that an internal auditing team, closely related to the GRC team, would be tasked with introducing and following the methodology of an internal audit. This process would consist of identifying the scope of the audit and the overall objectives. Then it will be decided which individuals are required to help assist in the completion of the audit including experts within the department that is being audited. In the case of an external audit, an auditor with the appropriate industry specific experience and knowledge would be required to ensure that the audit is completed to a standard that both parties are happy with, this also helps maintain the confidentiality of the audit.

7.1.1 NIST 800-53 SC-5 Denial-Of-Service Protection Auditing Methodology

“Organizations employ a range of security tools and architectural strategies to mitigate the impact of DoS attacks” (NIST, 2020). To audit this control in the case of BAE, it is important to note the amount of high-security demands due to the sensitivity of the information assets stored in systems and its related data. An audit therefore of SC-5 in this context involves both technical evaluation and policy compliance.

Firstly, the scope and objectives of the audit would begin with the identification of systems, services and network components that fall under the SC-5, with prioritisation over high-value assets including military project data and intellectual property storage servers and network access systems. Secondly, reassessing the current actions under the controls such as rate-limiting and internal network segmentation and DDoS mitigation tools would be expected. With Stallings (2017) suggesting that “layered defences and resilient architectures are key to preventing service degradation from DoS attacks”. Performing replication of DoS attacks would ensure that that both internal blue and red teams are able to understand the effects that are visualised through tabletop exercises with added reassurance that existing controls are sufficient for the protection of information assets. There may also be a suggestion that the implementation of real-time traffic monitoring through the SOC team would help to increase the monitoring capabilities associated with this control with timely detection helping to neutralise threats before they affect critical information assets (Zhang et al, 2018).

Additionally, the introduction of AI & Machine Learning could have a positive impact in the monitoring capabilities of the internal SOC teams, potentially being able to predict and pre-empt DOS behaviour for layer 7 attacks at the cost of increased computational resources (Kim et al, 2021).

7.1.2 Data Leakage Prevention ISO/IEC 27002 8.12 Auditing Methodology

"Organizations shall implement controls to prevent data leakage via endpoints, networks, cloud services, and physical media" (ISO/IEC, 2022). Following a similar auditing methodology as shown in the previous control example the focus of this control is the prevention of data leaking through rogue insider threats. To audit the control and assess the success of the actions taken to enforce the control we can begin by focusing on the higher value information assets and the access that individuals have. It would also prove beneficial to review any access requirements and handle the revoking or updating of these rights through the appropriate IAM department.

Along with this, it's important that any incidents regarding individuals even mistakenly retrieving sensitive information assets such as military project data or intellectual property or its related data should be logged and this log should be maintained with comments and review at a regular interval. In addition to this the introduction of zero trust architectures could benefit to prevent the lateral movement of data internally at BAE (Vishwakarma, 2020).

7.1.3 ISO 27001:2022 Annex A 5.21 Auditing Methodology

"Controls relevant to information security shall be agreed upon with suppliers and monitored" (ISO/IEC 27001, 2022). The importance of maintaining secure standards between third parties and BAE is especially important given the sensitive data that is handled on a day to day basis during normal business operations, this is much more the case than at other companies. The auditing process for this control would be a much more complex process as each individual business relationship would have to be identified and classified depending on the access and usage of sensitive data. Additionally, the contracts between the two parties which lay the foundation of the security standard that is expected between the two parties would also have to be reviewed by a legal advisor or auditor on a regular basis to ensure it meets the requirements that are necessary for accepting government and military contracts, which are the main sources of income for BAE systems.

A risk assessment would have to be concluded on the shared infrastructure between the two parties with a focus on active monitoring on these channels and increase network segregation. There may also be a shared incident response collaboration where both businesses' cyber divisions, namely the SOC departments, work together to reach a higher level of security monitoring, as the effectiveness of a company's information security is often only as strong as that of its third parties (Georgiadou et al, 2021).

Other auditing changes that could increase the supply chain security controls could be including the use of ISO 28000 or the Information Standard for Supply Chain Security Management Systems (ISO, 2022).

7.1.4 NIST 800-53 AT-2 Literacy Training and Awareness Auditing Methodology

"Organizations shall provide basic security awareness training to all users" (NIST, 2020). AT-2 mandates that employees receive regular training to understand their roles in protecting systems and information assets. The auditing of this control is then highly important to maintaining that the quality of the education received by employees is up to standard and that the employees themselves are taking the severity of the issue into account when operating their day to day roles.

The auditing process would begin by reviewing the existing training programs, ensuring all the content that is covered in the program is up to date and up to the quality expected in the control documentation, this would be the responsibility of the Cyber Awareness and Training department. Secondly, the attendance and completion must be checked using the records kept by the IAM team to ensure that the individuals whose roles depend on higher or more advanced training courses are completed and done in a timely manner so there is not a backlog of personnel without proper training. Further, there must be appropriate review and simulation of social engineering attacks to check whether the employees are continually aware of the threat of insider and external threat actors in their day to day roles. And finally the continual improvement of the quality of these courses provided by the Cyber Awareness and Training Department must be regularly checked and assessed by a third party assessor or accreditation organisation, with it being noted that security training being most effective when tailored and reinforced over a long period of time (Sasse et al, 2016).

On top of the review of all courses, the implementation of some gamified learning platforms may increase the attentiveness and retention of security content for those not seemingly interested in security concepts.

7.2 Metric and Evidence of Success

Using Key Performance Indicators, testing and quantitative data to back up the performance of the controls is an important way to propose further implementations of other controls to board members of BAE that lack the understanding of cyber security concepts and workflows. Implementing KPIs such as reported number of phishing attempts or amount of traffic attempting to access certain domains or network devices can be formatted into documentation that provides clear graphs and metrics that highlight the effectiveness of the controls implementation, on top of this a comparison data from before and after the implementation of future controls can further the evidence towards a more total policy implementation of control documentation that increases the security consciousness across the entire organisation.

References

Companies House (n.d.) *BAE Systems PLC*. Available at: <https://find-and-update.company-information.service.gov.uk/company/01470151> [Accessed 9th February 2025].

Defence IQ (n.d.) 'Top 10 Defence Companies: BAE Systems #3'. Available at: <https://www.defenceiq.com/air-land-and-sea-defence-services/articles/top-10-defence-companies-bae-systems-3> [Accessed 9th February 2025].

BAE Systems (n.d.-a) *Where we operate*. Available at: <https://www.baesystems.com/en/our-company/about-us#:~:text=what%20really%20matters.,Where%20we%20operate,people%20in%20around%2040%20countries> [Accessed 10th February 2025].

BAE Systems (n.d.-b) *How our business works*. Available at: <https://www.baesystems.com/en/sustainability/governance/oversight/how-our-business-works> [Accessed 10th February 2025].

BAE Systems, (2024-b). *BAE Systems awarded \$2.5 billion in contracts with Denmark and Sweden for new CV90 combat vehicles*. [online] BAE Systems. Available at: <https://www.baesystems.com/en/article/bae-systems-awarded-contracts-with-denmark-and-sweden-for-new-cv90-combat-vehicles> [Accessed 19 Apr. 2025].

BAE Systems, (2024-c). *Investment in technology and R&D*. [online] Available at: <https://www.baesystems.com/en/sustainability/investment-in-technology-and-research-and-development> [Accessed 19 Apr. 2025].

BAE Systems, (2024-d). *Patents*. [online] Available at: <https://www.baesystems.com/en/productfamily/fast-labs/patents> [Accessed 19 Apr. 2025].

BAE Systems. (2024-e). *What is the cyber risk associated with supply chains?* Available at: <https://www.baesystems.com/en/digital/blog/what-is-the-cyber-risk-associated-with-supply-chains> [Accessed 10th February 2025]

BAE Systems (2024) *Half-yearly Report 2024*. London: BAE Systems plc [Accessed 10th February 2025].

UK Ministry of Defence (2017) *Security requirements for List X contractors*. Available at: https://assets.publishing.service.gov.uk/media/5a7562a9ed915d6faf2b292b/Security_Requirements_for_List_X_Contractors.pdf [Accessed 10th February 2025].

Coates, S. (2024) 'China hacked Ministry of Defence, Sky News learns.' *Sky News*. [Online] 7th May 2024 <https://news.sky.com/story/china-hacked-ministry-of-defence-sky-news-learns-13130757> [Accessed 10th February 2025]

National Cyber Security Centre (NCSC) (n.d.). *Cyber Security Toolkit for Boards*. National Cyber Security Centre. Available at: https://www.ncsc.gov.uk/files/NCSC_Cyber-Security-Board-Toolkit.pdf [Accessed on 13th February 2025].

National Institute of Standards and Technology (NIST) (2024) *The NIST Cybersecurity Framework (CSF) 2.0*. Available at: <https://doi.org/10.6028/NIST.CSWP.29> [Accessed 13 February 2025].

CrowdStrike, (2025). *What is a Security Operations Center (SOC)?* [online] Available at: <https://www.crowdstrike.com/en-us/cybersecurity-101/next-gen-siem/security-operations-center-soc/#:~:text=What%20is%20a%20SOC?,and%20respond%20to%20security%20threats> [Accessed 27 February 2025].

Nathans, D. (2015) 'Infrastructure', in *Designing and Building a Security Operations Center*. Waltham, MA: Syngress, pp. 49–84.

UK Cyber Security Council. (n.d.). *Cyber security governance & risk management*. UK Cyber Security Council. Available at: <https://www.ukcybersecuritycouncil.org.uk/careers-and-learning/cyber-career-framework/cyber-security-governance-risk-management/> [Accessed 27 Mar. 2025].

International Organization for Standardization (ISO), 2018. *ISO/IEC 27000:2018 – Information security management systems – Overview and vocabulary*. Geneva: ISO.

Fortinet, 2024. *CIA Triad – Confidentiality, Integrity, and Availability*. [online] Available at: <https://www.fortinet.com/uk/resources/cyberglossary/cia-triad> [Accessed 28 March 2025].

Pender-Bey, G. (2012) 'The Parkerian Hexad: The CIA Triad Model Expanded'. Master's thesis, Lewis University. Available at: <https://cs.lewisu.edu/mathcs/msisprojects/papers/georgiependerbey.pdf> [Accessed 28 March 2025]

International Organization for Standardization (ISO) (2013) *ISO/IEC 27001:2013 – Information technology – Security techniques – Information security management systems – Requirements*. Geneva: ISO.

U.S. Department of Defense. (2024). *Weapons Procurement, FY 2025 Budget Estimates*. [pdf] Washington, D.C.: Office of the Under Secretary of Defense (Comptroller). Available at: https://comptroller.defense.gov/Portals/45/Documents/defbudget/FY2025/FY2025_Weapons.pdf [Accessed 19 Apr. 2025].

Check Point Software Technologies. (n.d.). *Nation-state level cyberattacks*. Available at: <https://www.checkpoint.com/cyber-hub/cyber-security/what-is-cyber-attack/nation-state-level-cyberattacks/> [Accessed April 19. 2025].

Securonix. (n.d.). *Edward Snowden – The ultimate insider threat*. Available at: <https://www.securonix.com/blog/edward-snowden-the-ultimate-insider-threat/> [Accessed April 19. 2025].

Cloudflare (n.d.). *What is a DDoS attack?*. Available at: <https://www.cloudflare.com/en-gb/learning/ddos/what-is-a-ddos-attack/> [Accessed April 19. 2025].

Risto, J., (2023). *What is Common Vulnerability Scoring System (CVSS Score)*. [online] SANS Institute. Available at: <https://www.sans.org/blog/what-is-cvss/> [Accessed 19 Apr. 2025].

National Institute of Standards and Technology (NIST), 2025. *CVSS v3 Calculator*. [online] National Vulnerability Database. Available at: <https://nvd.nist.gov/vuln-metrics/cvss/v3-calculator> [Accessed 19 Apr. 2025].

BBC News (2022) *Nato investigates hacker sale of missile firm data* [Online] Available at: <https://www.bbc.co.uk/news/technology-62672184> [Accessed 20 April 2025].

Information Commissioner's Office (ICO). (2023). *Learning from the Mistakes of Others: A Retrospective Review – Supply Chain Attacks*. Available at: <https://ico.org.uk/about-the-ico/research-reports-impact-and-evaluation/research-and-reports/learning-from-the-mistakes-of-others-a-retrospective-review/supply-chain-attacks/> [Accessed 21 April 2025].

Information Commissioner's Office (ICO). (2024). *Learning from the Mistakes of Others: A Retrospective Review – Phishing*. Retrieved April 21, 2025, from <https://ico.org.uk/about-the-ico/research-reports-impact-and-evaluation/research-and-reports/learning-from-the-mistakes-of-others-a-retrospective-review/phishing/>

National Institute of Standards and Technology (NIST), (2020). *Security and Privacy Controls for Information Systems and Organizations*. NIST Special Publication 800-53, Revision 5.1. [online] Gaithersburg, MD: U.S. Department of Commerce. Available at: <https://doi.org/10.6028/NIST.SP.800-53r5> [Accessed 21 Apr. 2025].

IBM, (2021). *What are Security Controls?* [online] IBM. Available at: <https://www.ibm.com/think/topics/security-controls> [Accessed 21 Apr. 2025].

Kosling, K., (2024). *ISO 27001:2022 Annex A Controls – A Complete Guide*. [online] IT Governance. Available at: <https://www.itgovernance.co.uk/blog/iso-27001-the-14-control-sets-of-annex-a-explained> [Accessed 21 Apr. 2025].

Securious, (2025). *ISO 27001 – The Ultimate UK Guide*. [online] Available at: <https://securious.co.uk/iso-27001-the-ultimate-uk-guide/> [Accessed 21 Apr. 2025].

ISMS.online. (2022). *ISO 27001:2022 Annex A Control 5.21 Explained*. Available at: <https://www.isms.online/iso-27001/annex-a/5-21-managing-information-security-ict-supply-chain-2022/> [Accessed 21 Apr. 2025].

AuditBoard, (2023). *What is an ISO Audit?* [online] AuditBoard. Available at: <https://auditboard.com/blog/what-is-iso-audit/> [Accessed 12 Apr. 2025].

Stallings, W., (2017). *Network Security Essentials: Applications and Standards*. 6th ed. Pearson.

Zhang, Y., Yu, F.R., Ning, B. and Liu, H., (2018). *Deep reinforcement learning for DDoS attack detection and mitigation*. IEEE Transactions on Network Science and Engineering, 7(1), pp.1-13.

Kim, T., Kim, H., & Kim, D., 2021. *Deep Learning-Based Detection of DDoS Attacks in Software-Defined Networks*. Sensors, 21(9), 3087.

ISO/IEC, 2022. *ISO/IEC 27002:2022 - Information security, cybersecurity and privacy protection — Controls*. ISO.

Vishwakarma, M. & Jain, A., 2020. *Data leakage detection and prevention techniques: A survey*. International Journal of Information Security, 19, pp.157-175.

Georgiadou, A., Mouzakitis, S. & Askounis, D., 2021. *Assessing the security risks in supply chains: A systematic literature review*. Computers & Security, 99, 102049.

International Organization for Standardization (ISO). (2022). *ISO 28000:2022 Security and resilience — Security management systems — Requirements*. 2nd ed. Geneva: ISO. Available at: <https://www.iso.org/standard/79612.html> [Accessed 21 Apr. 2025].

Sasse, M.A., Brostoff, S. and Weirich, D., 2016. *Transforming the 'weakest link': A human/computer interaction approach to usable and effective security*. BT Technology Journal, 19(3), pp.122-131.

